VULNBANK

WEB APPLICATION VULNERABILITY ASSESSMENT AND PENETRATION TEST REPORT

Prepared from supplied testing evidence
Evidence dates: 27 October 2026 and 8 November 2026
Report date: 8 November 2026
CONFIDENTIAL – SECURITY ASSESSMENT

Document control

Field	Value
Target	https://vulnbank.org
Assessment	External web application VAPT – evidence-based draft
Evidence dates	27 October 2026 and 8 November 2026
Prepared by	Assessment analyst (name not supplied)
Status	Draft – confirm authorization, scope and rules of engagement
Handling	Confidential; need-to-know distribution only

Important scope and evidence caveat

This report is drafted solely from supplied screenshots. It does not establish that all testing was completed, that the target owner authorized the activity, or that every issue was independently reproduced. Confirm written authorization, in-scope assets, test windows and rules of engagement before treating this as final.

Executive summary

The strongest evidence is a directory-enumeration result showing /.env returning HTTP 200 (~571 bytes), accompanied by a screenshot containing application secrets, database credentials, Redis details, an API key and SMTP credentials. If unauthenticated retrieval from the target is confirmed, this is a Critical sensitive-information disclosure.

Other screenshots show responding API/console routes, a successful login exchange, a decoded JWT with an administrative claim, an admin UI and a large displayed balance. These do not independently prove unauthorized admin access, JWT forgery, IDOR or server-side financial manipulation; they require controlled validation.

Risk	Summary
Critical	1 provisional finding – exposed environment configuration
High	0 confirmed
Medium	0 confirmed; route exposure requires validation
Informational	Service discovery and hardening observations
Not proven	Privilege escalation, JWT tampering, IDOR, financial logic manipulation

Immediate actions

• Remove /.env from web-accessible paths and verify 403/404.

• Rotate every potentially exposed secret and credential; invalidate affected sessions and tokens.

• Disable production debug mode.

• Review web, application, database, Redis, SMTP and identity logs for access or misuse.

• Do not reproduce raw secrets or tokens in tickets or reports.

1. Assessment overview

Objective

Review the externally observable security posture represented by the supplied reconnaissance, browser and HTTP proxy evidence.

Evidence and methodology

Evidence	What it supports
Nmap	HTTP/HTTPS/8080 observations through Cloudflare
Directory enumeration	Routes and response codes, including /.env
Environment screenshot	Sensitive configuration values appear in retrieved content
Burp login exchange	POST /login returns HTTP 200 and a success response with a session token
JWT debugger	Decoded payload contains an admin-role claim; signature validity is not established
Admin/dashboard screenshots	Administrative UI and displayed account balance; access control and backend integrity not proven

The evidence does not include complete test logs, a role matrix, server logs, or retest results. Findings are separated from observations requiring validation.

2. Findings

VULN-01 – Public exposure of application environment configuration

Attribute	Assessment
Severity	CRITICAL – provisional, assuming unauthenticated retrieval
Category	Sensitive information disclosure / security misconfiguration
Affected path	https://vulnbank.org/.env
Evidence	Enumeration reports HTTP 200 and ~571 bytes; screenshot shows application, database, Redis, API and SMTP configuration.
Confidence	High for screenshot content; independently reproduce reachability within authorization.

Description

The enumeration output reports /.env as HTTP 200. The accompanying screenshot displays secret-key variables, database connection details, Redis configuration, a third-party API key and SMTP credentials. Values are redacted in this report.

Impact

• Signing secrets may enable token forgery depending on implementation.

• Database/Redis credentials may enable unauthorized access if reachable and sufficiently privileged.

• SMTP credentials may enable mail-service abuse.

• Third-party API keys may allow unauthorized use of connected services.

• Debug mode in a production-labelled environment increases exposure risk.

Remediation

• Remove the file from the document root and deny dotfile access at the web server/CDN.

• Rotate all exposed credentials and keys; invalidate sessions/tokens signed with exposed keys.

• Store secrets in a managed secret store or protected deployment environment.

• Disable debug mode in production and add deployment checks.

• Review access logs for successful requests to /.env and related variants.

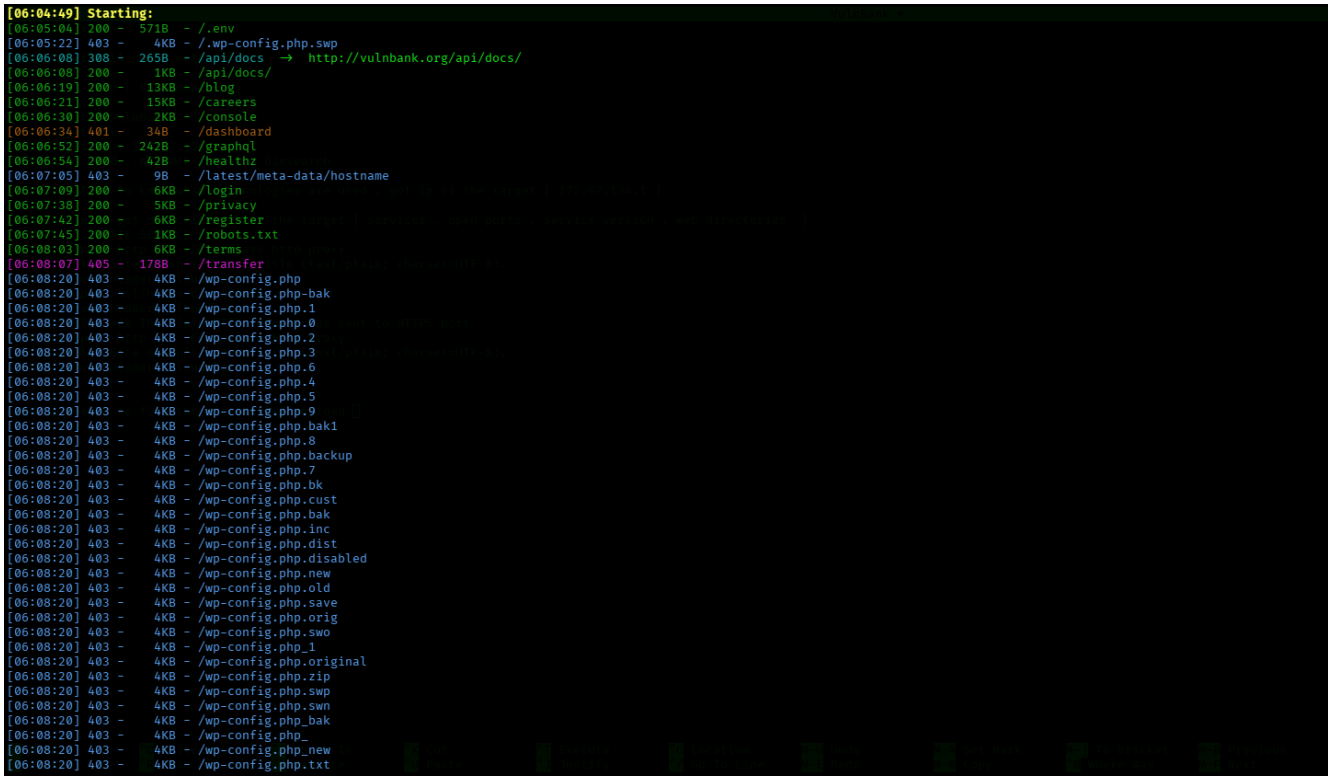


Figure 1. Enumeration output: /.env returned HTTP 200 (~571 bytes).



Figure 2. Environment configuration screenshot with secret values redacted.

VULN-02 – Application routes and diagnostic interfaces exposed for review

Attribute	Assessment
Severity	Informational pending validation
Paths	/api/docs, /console, /healthz, /graphql
Evidence	Directory enumeration reports successful responses; /api/docs redirects and then returns HTTP 200.
Confidence	High for route responses; impact not established.

A successful response alone is not a vulnerability. Determine whether these routes expose internal schemas, operational data, diagnostics or administrative actions.

• Require authentication and role authorization for non-public docs and console interfaces.

• Limit health endpoints to minimal liveness/readiness data.

• Restrict GraphQL introspection if unnecessary; enforce object-level authorization and query limits.

• Review whether /console is intended to be public.

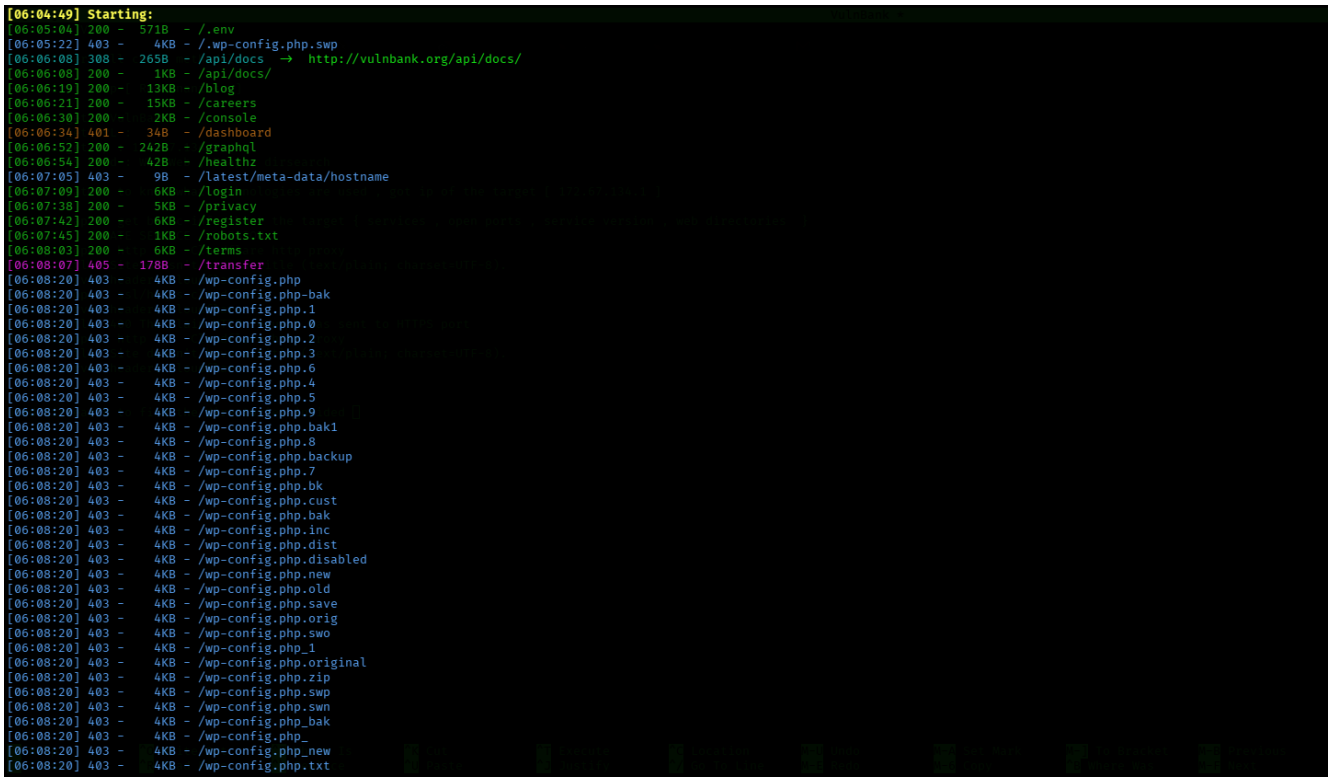


Figure 3. Discovered routes and response codes.

VULN-03 – Session cookie attributes require verification

Attribute	Assessment
Severity	Low / hardening observation
Evidence	Captured Set-Cookie fragment shows HttpOnly and Path=/; Secure and SameSite are not visible.
Confidence	Medium; review full raw response before confirming absence.

Set Secure and an appropriate SameSite value on session cookies, retain HttpOnly, and use suitable session expiry and revocation. The screenshot may omit header content, so this is not confirmed.

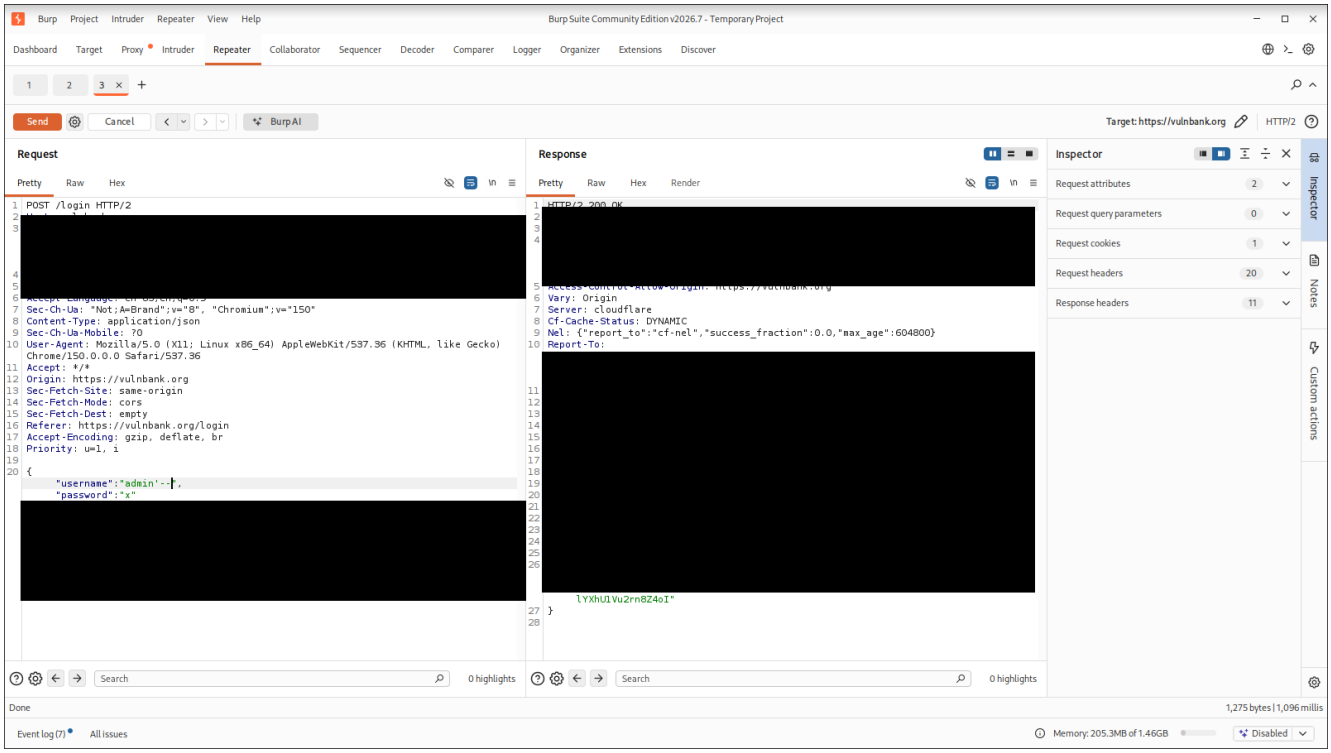


Figure 4. Redacted Burp login exchange.

3. Observations requiring validation

Administrative interface and JWT role claim

The admin UI is visible and a separate JWT debugger decodes a payload containing an administrative claim. Decoding does not verify the signature, and screenshots do not prove unauthorized access. Validate with authorized standard-user and admin test accounts. Confirm server-side authorization, signature enforcement, algorithm allowlisting, issuer/audience checks, expiry and trusted role assignment.

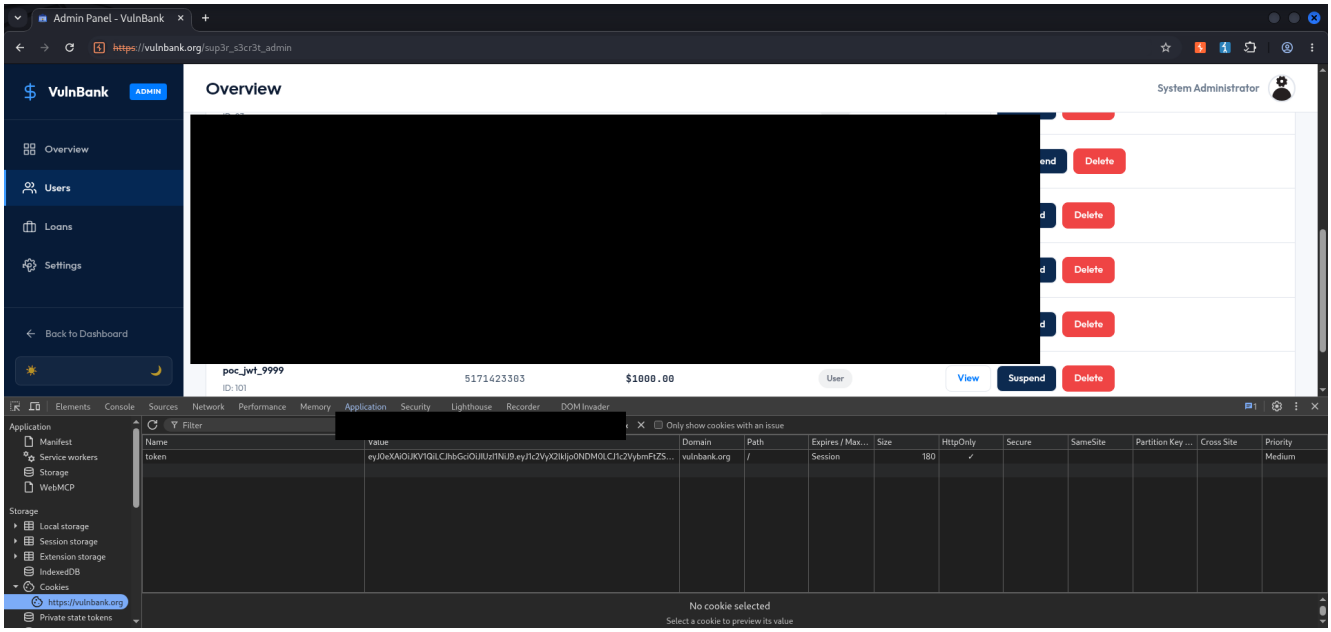


Figure 5. Admin user-management UI; identifiers and balances redacted.

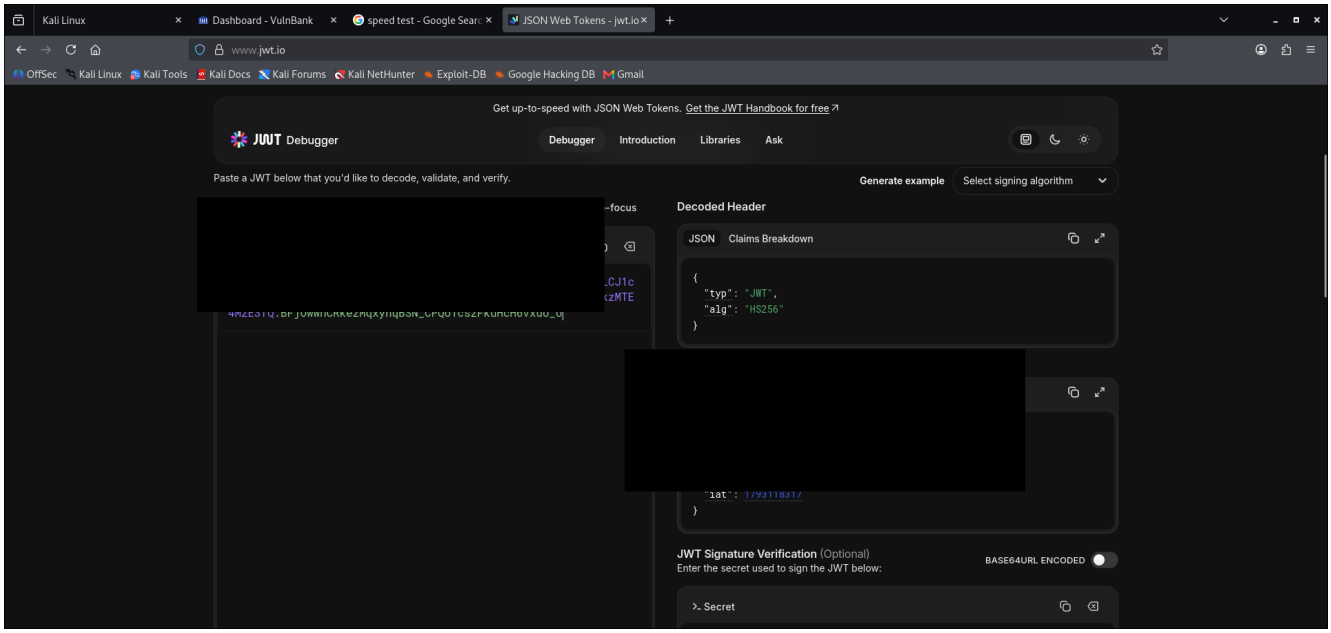


Figure 6. JWT debugger; encoded token and claims redacted.

Unusually large displayed account balance

A dashboard shows an unusually large balance, but a UI display is not proof of backend manipulation. Verify server-side returned values, persistence after re-login, and transaction limit/funds enforcement using test accounts only. Do not initiate real transfers.

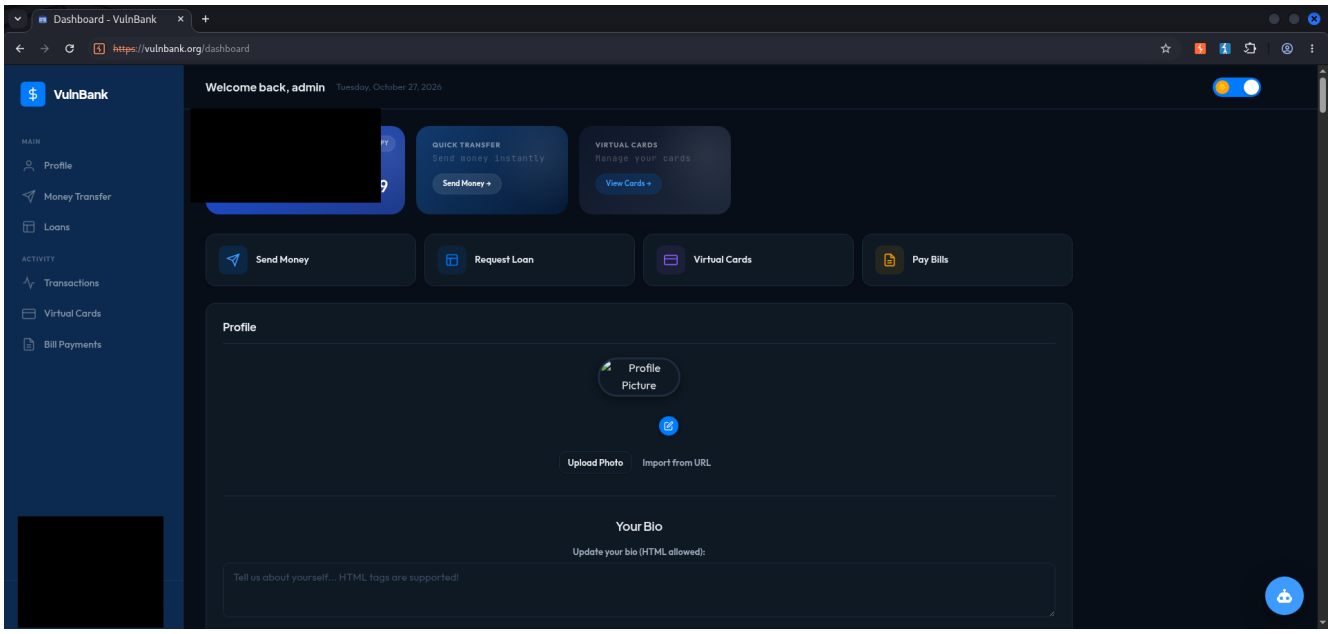


Figure 7. Dashboard with account details and balance redacted.

Login API response

POST /login returns HTTP 200 with a success status, token and account attributes. This is consistent with successful authentication and does not prove bypass. Review whether unnecessary sensitive fields are returned and whether failures are handled consistently.

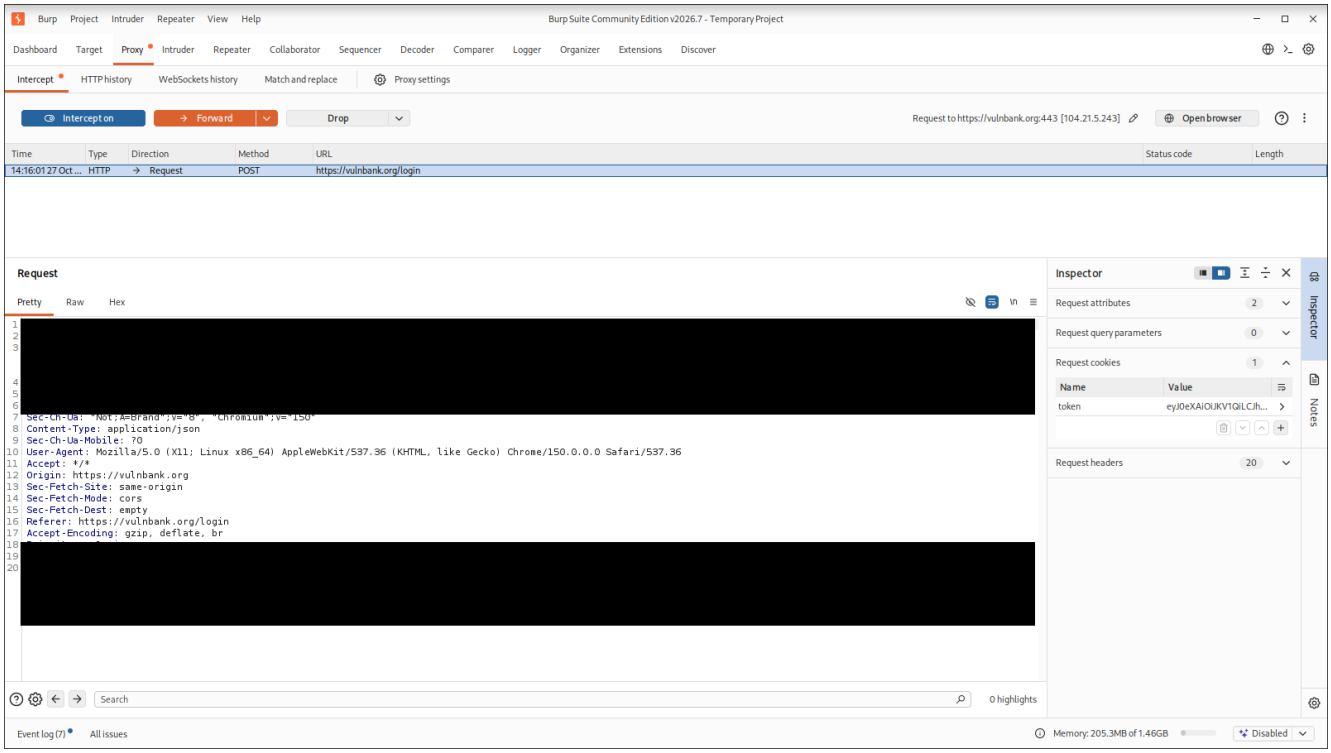


Figure 8. Redacted login request.

Network/service discovery

Nmap reports ports 80, 443 and 8080 with Cloudflare identified as the HTTP proxy. The displayed address appears to be an edge address and is not a definitive origin-server service inventory.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV -D RND:3 172.67.134.11 -oN Vulnbank-info.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-11-08 05:55 -0500
Nmap scan report for 172.67.134.11
Host is up (0.00069s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE   VERSION
80/tcp   open  http      Cloudflare http proxy
|_http-title: Site doesn't have a title (text/plain; charset=UTF-8).
|_http-server-header: cloudflare
443/tcp  open  ssl/https cloudflare
|_http-server-header: cloudflare
|_http-title: 400 The plain HTTP request was sent to HTTPS port
8080/tcp open  http      Cloudflare http proxy
|_http-title: Site doesn't have a title (text/plain; charset=UTF-8).
|_http-server-header: cloudflare

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 209.11 seconds
```

Figure 9. Nmap service discovery output.

4. Remediation plan

Priority	Action	Timeframe
P0	Remove .env exposure; rotate secrets; invalidate affected sessions/tokens.	Immediately / 24h
P1	Review logs for access and credential misuse; assess dependent service exposure.	24–48h

Priority	Action	Timeframe
P1	Disable production debug mode and improve secret storage.	Within 3 days
P2	Review docs, console, GraphQL and health endpoint access controls.	Within 7 days
P2	Verify cookie attributes and session lifecycle.	Within 7 days
P3	Test role authorization and server-side balance integrity with test accounts.	Authorized retest

5. Limitations

• Evidence is screenshot-based; no independent reproduction is claimed.

• No complete HTTP exports, source review, role matrix or server logs were supplied.

• Cloudflare edge observations do not establish origin services.

• No successful JWT forgery, privilege escalation, IDOR, SQL injection, RCE or transaction manipulation is claimed.

• Authorization and rules of engagement were not supplied and must be documented.

6. Retest checklist

• ■ Unauthenticated /.env returns 403/404 and no cached secret copies remain.

• ■ All exposed secrets are rotated and old sessions/tokens are invalid.

• ■ Production debug mode is disabled.

• ■ Docs, console, GraphQL and health endpoints expose only intended information.

• ■ Standard users cannot invoke admin functions.

• ■ Tampered/invalid JWTs are rejected server-side.

• ■ Session cookies have Secure, HttpOnly and appropriate SameSite attributes.

• ■ Balances and transaction limits are enforced server-side.

• ■ Logs show no unexplained access to configuration or credential misuse.

Appendix – Evidence handling

Screenshots in this report have been redacted to conceal tokens, passwords, API keys, connection strings, account identifiers, user names and/or balances. Store original evidence in a restricted repository with access logging. The Critical rating for VULN-01 assumes unauthenticated retrieval; calibrate final severity after confirming reachability, secret validity, privileges and business impact.